MITRE ATLAS | AML.CS0029 - Google Bard Conversation Exfiltration

Entry Information

ID:
AML.CS0029

Type:
Case-Study

Name:
Google Bard Conversation Exfiltration

URL:
https://atlas.mitre.org/studies/AML.CS0029/

Incident Date:
2023-11-23

Target:
Google Bard

Actor:
Embrace the Red

Description

[Embrace the Red](https://embracethered.com/blog/) demonstrated that Bard users' conversations could be exfiltrated via an indirect prompt injection. To execute the attack, a threat actor shares a Google Doc containing the prompt with the target user who then interacts with the document via Bard to inadvertently execute the prompt. The prompt causes Bard to respond with the markdown for an image, whose URL has the user's conversation secretly embedded. Bard renders the image for the user, creating an automatic request to an adversary-controlled script and exfiltrating the user's conversation. The request is not blocked by Google's Content Security Policy (CSP), because the script is hosted as a Google Apps Script with a Google-owned domain.

Note: Google has fixed this vulnerability. The CSP remains the same, and Bard can still render images for the user, so there may be some filtering of data embedded in URLs.

Attack Procedure:
[AML.T0065] LLM Prompt Crafting: The researcher developed a prompt that causes Bard to include a Markdown element for an image with the user's conversation embedded in the URL as part of its responses.
[AML.T0008] Acquire Infrastructure: The researcher identified that Google Apps Scripts can be invoked via a URL on `script.google.com` or `googleusercontent.com` and can be configured to not require authentication. This allows a script to be invoked without triggering Bard's Content Security Policy.
[AML.T0017] Develop Capabilities: The researcher wrote a Google Apps Script that logs all query parameters to a Google Doc.
[AML.T0093] Prompt Infiltration via Public-Facing Application: The researcher shares a Google Doc containing the malicious prompt with the target user. This exploits the fact that Bard Extensions allow Bard to access a user's documents.
[AML.T0051.001] Indirect: When the user makes a query that results in the document being retrieved, the embedded prompt is executed. The malicious prompt causes Bard to respond with markdown for an image whose URL points to the researcher's Google App Script with the user's conversation in a query

parameter.

[AML.T0077] LLM Response Rendering: Bard automatically renders the markdown, which sends the request to the Google App Script, exfiltrating the user's conversation. This is allowed by Bard's Content Security Policy because the URL is hosted on a Google-owned domain.

[AML.T0048.003] User Harm: The user's conversation is exfiltrated, violating their privacy, and possibly enabling further targeted attacks.

References

- Hacking Google Bard - From Prompt Injection to Data Exfiltration — https://embracethered.com/blog/posts/2023/google-bard-data-exfiltration/